

Information Security

Information Security Foundation

- What is Information Security?
- Information Security Services
- Information Security Terminology
- Information Security Challenges
- Security Functional Requirements
- Layers in a Defense-in-Depth Strategy
- Fundamental Security Design Principles
- Information Security Mechanisms

What is Information Security?

- Information security is concerned with protecting information from unauthorized access.



What is Information Security?

- According to National Institute of Standards and Technology (NIST) and the National Information Assurance (NIA) Glossary,
- “Information security is the **protection of information and information systems** from **unauthorized access**, use, disclosure, disruption, modification, or destruction in order to provide **confidentiality, integrity, and availability**.”

What is Information Security?

- Security = Sustain desirable properties under intelligent adversaries
 - An **adversary** is a subject who tries to gain unauthorized access
- Desirable properties
 - Understand what properties are needed.
- Intelligent adversaries
 - Needs to understand/model adversaries

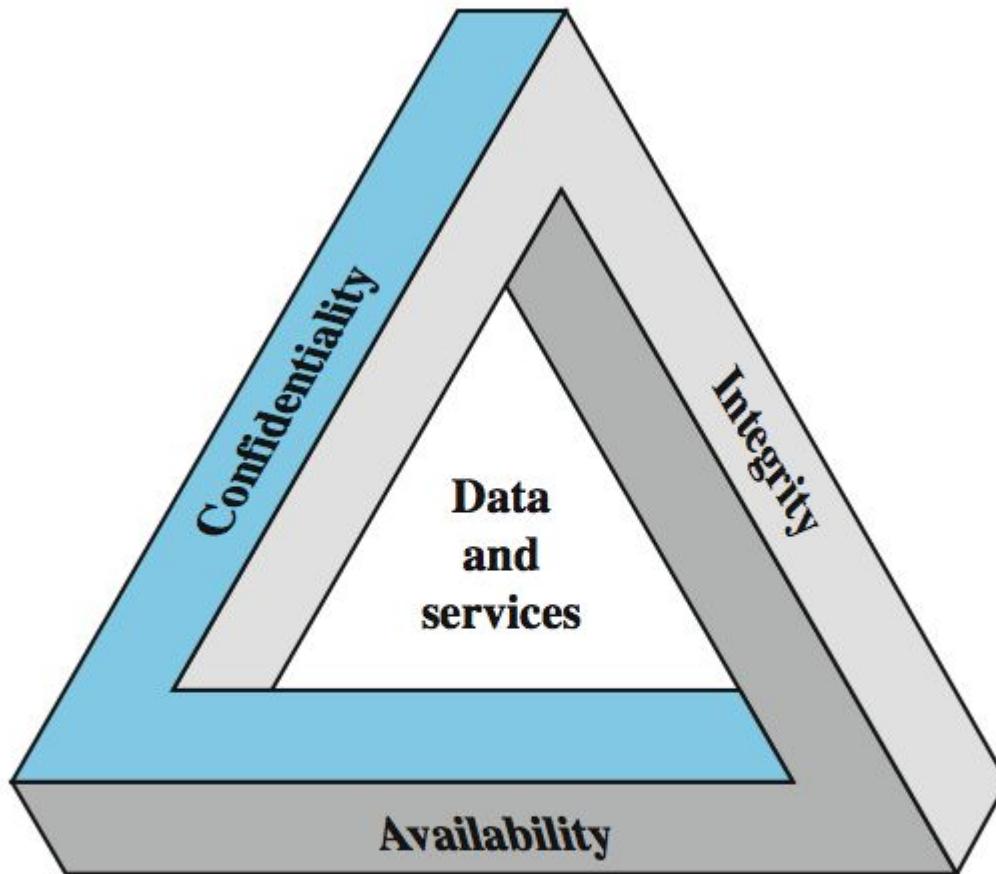
Information Security Services

- Confidentiality:
 - Information **only** accessible to authorized entities
 - Threat: Non-authorized access to data or traffic analysis
- Integrity:
 - **Only** authorized entities can **modify** the information
 - Threat: Modification of data or introduction of false data
- Availability:
 - Guarantees the availability of the information for **authorized entities whenever required**
 - Threat: Elimination of data or resources

Information Security Services

- Authentication:
 - Authentication is the process of **validating the identity** of a registered user before allowing access to the protected resource
 - Threat: Third-party masquerading as sender / receiver
- Non-repudiation:
 - Guarantees that sender and receiver of a message **can't deny its transmission**
 - Threat: Deny having transmitted or received certain data
- Access Control:
 - Guarantees controlled access to information and systems to authorized entities
 - Threat: Access of confidential data to non authorized entities

Key Security Concepts



Information Security Terminology

- An **adversary** is a subject who tries to gain **unauthorized access**
- A **threat** is any **potential danger** to information life cycle
- A **risk** is a **loss** due to an adversary gaining unauthorized access
- A **vulnerability** is a **flaw (bug)**, which enables a threat to allow the adversary for unauthorized access

Information Security Challenges

- Defense is almost always harder than attack.
- Information security is more difficult than physical security?
 - Adversaries can come from anywhere
 - Computers enable large-scale automation
 - Adversaries can be difficult to identify
 - Adversaries can be difficult to punish
 - Possible payoff can be much higher

FIPS-200 Security Functional Requirements (Federal Information Processing Standards)

- Technical Measures
 - Access control; identification & authentication; system & communication protection; system & information integrity
- Management Controls and Procedures
 - Awareness & training; audit & accountability; certification, accreditation & security assessments; incidental planning; maintenance; physical & environmental protection; planning; personnel security; risk assessment; systems & services acquisition
- Extending Technical and Management
 - Configuration management; incident response; media protection, contingency planning

Layers in a Defense-in-Depth Strategy

Layers in a Defense-in-Depth Strategy

